

Data Breach Incident Response Plan

Step-by-step response procedures, forms, checklists and communication templates for data incidents

Document ID	PLN-IR-001
Version	1.0 (template)
Classification	Internal
Owner	[Data Protection Officer / IT Security Manager]
Approved by	[Name, Title]
Effective date	[DD Month YYYY]
Next review	[DD Month YYYY — review at least annually]

Customization required

This template is a starting point published by the OpenDLP-LK community. Replace all bracketed placeholders, adapt the content to your organization's size, industry and risk profile, and obtain legal review before adoption. Aligned with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022.

<https://opendlp-lk.github.io> • Licensed under MIT — free to use, adapt and redistribute.

1. Purpose and Scope

This plan defines how [Organization Name] detects, contains, investigates, reports and recovers from incidents involving unauthorized access to, disclosure of, or loss of organizational or personal data. It applies to all personnel and all systems processing organizational data, and implements the breach notification obligations of PDPA Section 23.

2. Incident Response Team

Role	Name / Contact	Responsibilities
Incident Response Lead	[name, phone, email]	Declares incidents, coordinates response, approves communications.
Data Protection Officer	[name, phone, email]	Assesses PDPA impact; notifies the Data Protection Authority and data subjects.
IT Security Analyst	[name, phone, email]	Technical investigation, containment, evidence preservation.
Legal Counsel	[name, phone, email]	Legal exposure assessment; regulator and law-enforcement liaison.
HR Representative	[name, phone, email]	Insider-related incidents; disciplinary process.
Communications / PR	[name, phone, email]	Internal and external messaging; media handling.

24/7 reporting channel

All personnel must report suspected incidents immediately to [security@organization.lk] or hotline [+94 XX XXX XXXX]. Do not attempt to investigate or remediate on your own — you may destroy evidence.

3. Severity Classification

Level	Criteria	Response time	Escalation
Critical	Confirmed exposure of Restricted/special-category personal data; large-scale exfiltration; regulatory notification likely.	Immediate	CEO, DPO, Legal, full IRT
High	Confirmed exposure of Confidential data; single-system compromise with sensitive data at risk.	< 2 hours	IRT Lead, DPO
Medium	Policy violation with possible exposure; lost encrypted device; blocked exfiltration attempt.	< 8 hours	IT Security
Low	Minor violation, no evidence of exposure; false-positive-heavy alert cluster requiring tuning.	< 24 hours	DLP administrator

4. Response Phases

Phase 1 — Detection & Identification (0–2 hours)

- ☐ Record date/time of detection and detection source (DLP alert, user report, third party).
- ☐ Identify affected systems, data types and estimated number of records/data subjects.
- ☐ Classify severity using the matrix in Section 3.
- ☐ Open an incident record and assign an incident ID (IR-YYYY-NNN).
- ☐ Notify the Incident Response Lead.

Phase 2 — Containment (2–4 hours)

- ☐ Isolate affected systems from the network (do not power off unless directed — preserve memory evidence).
- ☐ Disable compromised accounts and revoke exposed credentials/tokens.
- ☐ Block relevant channels (email rule, USB block, cloud share revocation).
- ☐ Preserve logs, disk images and DLP alert records; start chain-of-custody form.
- ☐ Activate incident response team per severity.

Phase 3 — Investigation (4–24 hours)

- ☐ Determine root cause (attack vector, insider action, misconfiguration, error).
- ☐ Identify exactly what data was accessed, disclosed or lost, and for how long.
- ☐ Assess likelihood of harm to data subjects (identity theft, fraud, discrimination, reputational damage).
- ☐ Determine whether personal data of Sri Lankan data subjects is involved (triggers PDPA analysis).
- ☐ Document findings with timestamps and evidence references.

Phase 4 — Notification (24–72 hours)

- ☐ DPO determines whether the breach is notifiable to the Data Protection Authority under PDPA Section 23 and applicable rules.
- ☐ Submit DPA notification within the prescribed timeframe [72 hours from becoming aware, unless rules prescribe otherwise].
- ☐ Notify affected data subjects where there is likely risk of harm, with plain-language description and protective steps.
- ☐ Inform contractual parties (clients, insurers, banks) as required by agreements.
- ☐ Prepare holding statement and FAQ for media/customer-facing teams if public disclosure is likely.

Phase 5 — Recovery & Remediation

- ☐ Eradicate root cause (patch, reconfigure, remove malware, close account).
- ☐ Restore systems from clean backups; verify integrity before reconnection.
- ☐ Rotate all potentially exposed credentials and keys.
- ☐ Enhance DLP rules/monitoring for the exploited channel.
- ☐ Confirm normal operations and formally close containment.

Phase 6 — Lessons Learned (within 2 weeks)

- ☐ Hold post-incident review with full timeline reconstruction.
- ☐ Identify control gaps and assign corrective actions with owners and due dates.
- ☐ Update policies, procedures and this plan as needed.
- ☐ Brief staff / run targeted refresher training where human error contributed.
- ☐ File final incident report with management and retain for [5] years.

5. Incident Report Form

Incident ID:	
Date/time detected:	
Reported by:	
Detection source:	
Severity (C/H/M/L):	
Systems affected:	
Data types involved:	
Est. records / data subjects:	
Personal data involved (Y/N):	
Containment actions taken:	
DPA notification required (Y/N):	
Incident Lead signature:	

6. Communication Templates

6.1 Data Protection Authority notification (skeleton)

To: Data Protection Authority of Sri Lanka. From: [Organization Name], [address], DPO: [name, contact]. We hereby notify a personal data breach identified on [date/time]. Nature of breach: [unauthorized access / disclosure / loss / alteration]. Categories and approximate number of data subjects: [...]. Categories and approximate volume of personal data records: [...]. Likely consequences: [...]. Measures taken or proposed: [containment, remediation, subject notification]. Point of contact for further information: [...].

6.2 Data subject notification (skeleton)

Dear [Name], we are writing to inform you of a security incident that involved some of your personal information held by [Organization Name]. On [date] we discovered [brief plain-language description]. The information involved was: [...]. What we have done: [...]. What you can do: [monitor bank statements, change passwords, beware of phishing]. We sincerely regret this incident. For questions contact [helpline / email].

6.3 Internal all-staff notice (skeleton)

Team, we are responding to a data security incident affecting [system/scope]. Do not discuss the incident externally or on social media. Direct any external inquiries to [Communications lead]. If you notice suspicious activity, report it to [security contact] immediately.